SIMATS ENGINEERING

SIMATS

Saveetha Institute of Medical And Technical Sciences

(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I Namatha(192126019 *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Problem-Solving Approach	30	Logical, well structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethich hacking principles

Answer :

Ethical hacking is the process of identifying security weaknesses in computer systems with proper permission. An ethical hacker must follow professional rules and protect the client's systems and data.

In this situation, the company has provided only a one line email authorization without defining the scope of testing. During the test, I discover a critical vulnerability in a system that was not mentioned in the authorization.

Ethical hacking Principles:

1. **Authorization** : Test only systems for which pe has been granted.
2. **Responsibility** : Avoid actions that may dama systems or interrupt services.
3. **confidentiality** : Protect the client's sensit information.
4. **Honesty** : Report vulnerabilities truthfully hiding important details.
5. **Professionalism** : Follow agreed rules and approval before expanding the scope.

4. Unsecure data storage

In Android verification is specifically
authorized. I would use the least intrusive
method possible and avoid accessing unnecessary
data. I should not copy or store customer
financial records.

5. Treatment of vulnerability

I would record the affected application, the
general nature of the vulnerability, its potential
impact, and the steps needed to correct it.
Evidence should not contain unnecessary sensitive
information.

Precautions before the engagement

- Obtain written authorization from the client
- Define the scope of testing and identify excluded systems.
- Use a staging environment wherever possible
- Define incident reporting and stop testing conditions.

3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live Production Server, causing an outage. Walk through what you should have to prevent this and what your responsibility is now.

environment

attacker to interfere with database queries. If exploited carelessly, it can expose sensitive information or modify important records.

In this situation, I discover that the production database contains real customer financial information. Since financial data is highly sensitive, I must take extra precautions to protect the information and prevent damage.

Steps to proceed safely

1. **Stop risky testing**

I would pause any testing that could expose, modify, or delete customer data. I would not retrieve real financial records merely to demonstrate the vulnerability.

2. **Inform the client**

I would immediately notify the authorized client contact about the discovery. I would explain the possible risks of SQL injection and recommend a safer testing method.

3. **Use a test environment**

I would request a staging or test database containing dummy customer information. This would allow me to verify the vulnerability without affecting real customers.

4. Use a test environment.

Potentially disruptive tests should be performed in a controlled environment that closely resembles the production system.

5. Set monitoring and stop conditions.

The testing team should monitor system performance and have clear conditions for stopping immediately if unusual behaviour or service degradation occurs.

6. Prepare a recovery plan.

Before testing, the team should agree on emergency contacts, backup arrangements, recovery procedures and responsibilities

Responsibilities after the outage.

1. Stop testing immediately.

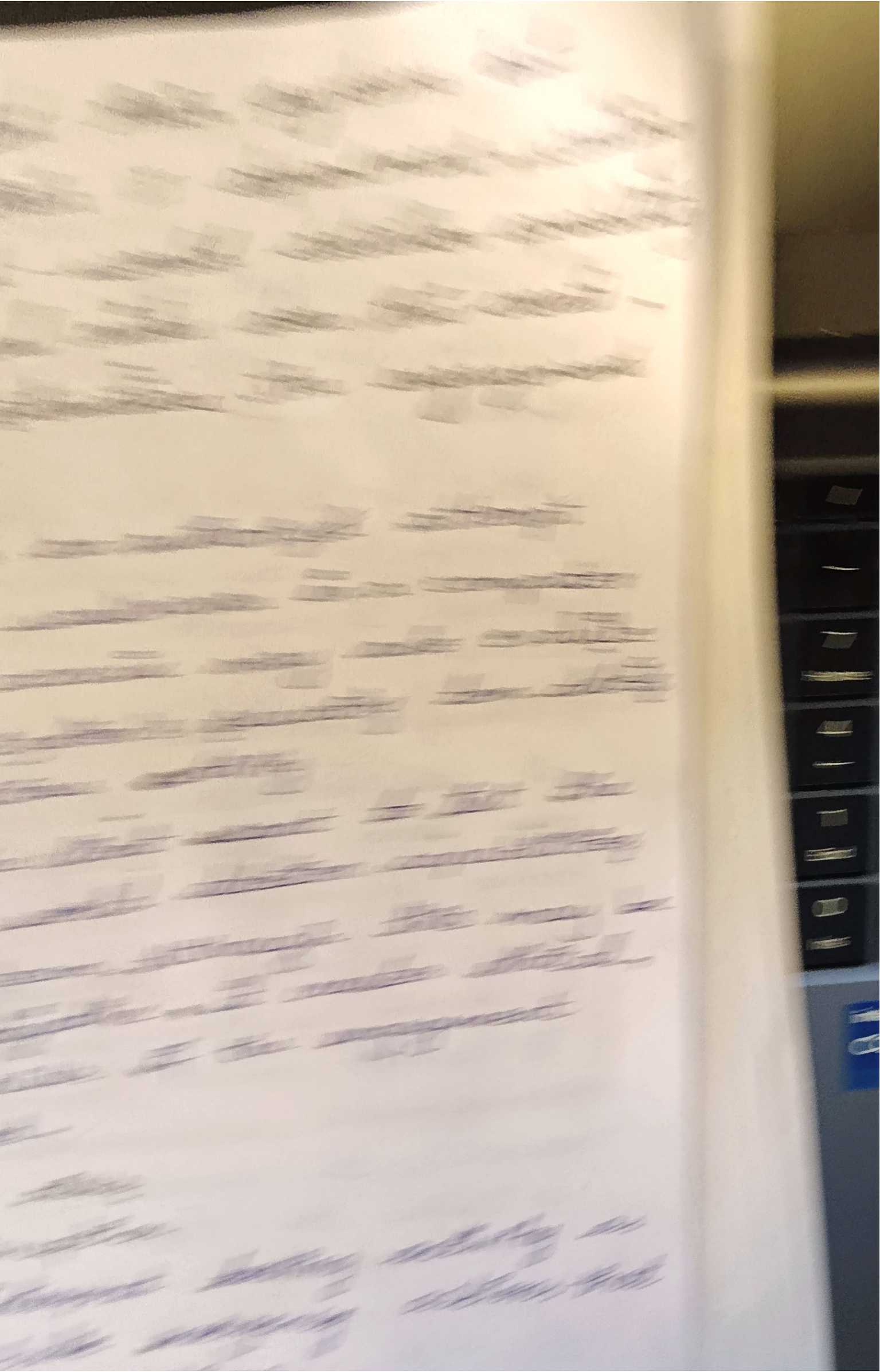
I would immediately stop the activity that caused the outage and avoid further actions that might worsen the situation.

2. Support recovery

I would cooperate with the client's IT team to restore normal operations according to the approved recovery procedure. I would not make unauthorized changes to production systems

3. Notify the client.

I would immediately inform the client's incident response team and authorized contact. I would clearly explain what happened and which services may be affected.



5. You're asked to perform a "red team" exercise versus - " ' ' - .

a. legal and authorization risks.

The person requesting the test may not have sufficient authority to approve every system or activity. Written authorization must cover all relevant systems and testing methods.

4. Risk to sensitive information.

Testing may unintentionally expose confidential business information, personal data, or customer records.

5. Damage to trust

If the exercise is poorly managed, the security team may lose trust in management or the testing organization.

How I would structure the engagement.

1. obtain written authorization.

I would obtain approval from an authorized management representative who has the authority to approve the exercise.

2. Define the slope.

The agreement should identify permitted systems, exclusive coordinator should be available to stop the test and coordinate emergency actio

3. Establish emergency contacts.

A designated controller or exercise coordinator should be available to stop the test and coordinatate emergency actions.

5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a banking system to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

A red them exercise and a vulnerability assessment are both used to improve an organization's cybersecurity. However, their objectives, methods and results are different.

A red team exercise simulates realistic attack scenarios to evaluate whether an organization can prevent, detect and respond to security threa

A vulnerability assessment identifies, analyzes, and prioritizes security weaknesses so that the organization can correct them.

1. Red team exercise in a banking system.

The main objective is to evaluate the bank's overall security defenses and incident response capabilities.

The exercise may assess authorized digital attack scenarios, employee security awareness, access-control procedures, and physical securit controls.

Email collection.

- Obtain written approval from authorized bank management.
- Utilize the mail system, locations, and other provided.
- Never use personal email accounts to transfer real money.
- Report suspected hacking issues or ATM operations
- Stay knowledgeable of the current trends in cybersecurity

Email considerations:

- Obtain authorization before accessing systems.
- Use safe attachment methods such antivirus programs.
- Avoid accessing methods like antivirus softwares
- Report suspicious emails immediately
- Ensure confidentiality of all findings.
- Utilize secure file and safely communicate recommendations with management